# GU?A PARA DEFENDER LA PR?CTICA 8

PHP: cookies, sesiones, autenticaci?n y datos temporales

Idea central
HTTP no conserva por s? mismo el estado entre peticiones. La pr?ctica combina una sesi?n almacenada en el servidor con cookies controladas y validadas para recordar al usuario y mostrar los ?ltimos anuncios visitados.

Guion de exposici?n, mapa de archivos, fragmentos de c?digo y pruebas r?pidas. Est? basado en el enunciado de la Pr?ctica 8 y en la implementaci?n actual del proyecto.

## Una explicaci?n de 30 segundos

?La aplicaci?n usa una sesi?n PHP para identificar al usuario en el servidor, protege cada ruta privada comprobando esa identidad y cambia el ID de sesi?n despu?s del login. La opci?n de recordar no guarda la contrase?a: guarda un token aleatorio en el navegador y su hash en el servidor. Flashdata comunica errores tras redirigir y una cookie aparte conserva hasta cuatro anuncios visitados durante una semana.?

## Ruta recomendada para la defensa

? 1. Explicar HTTP sin estado y la diferencia entre cookie y sesi?n.

? 2. Ense?ar el inicio de sesi?n y el guard de rutas privadas.

? 3. Explicar ?Recordarme? y por qu? no se guarda la contrase?a.

? 4. Demostrar flashdata, estilos por usuario y ?ltimos anuncios.

? 5. Cerrar sesi?n y mostrar qu? datos se invalidan.

# 1. Mapa del proyecto

includes/bootstrap.php ? Configura la zona horaria, inicia la sesi?n, ofrece funciones flash y procesa el auto-login.

includes/lib/funciones.php ? Funciones comunes: usuarioActual(), requiereUsuario(), redirigir(), saludoPorHora() y recordatorio.

includes/lib/datos.php ? Carga usuarios/anuncios y busca anuncios por ID real validado.

includes/procesadores/control_acceso.php ? Valida credenciales, renueva el ID de sesi?n, guarda identidad/estilo y crea el token opcional.

includes/procesadores/cerrar_sesion.php ? Revoca el recordatorio, limpia la sesi?n y borra las cookies de recordatorio y anuncios.

includes/procesadores/respuesta_registro.php ? Valida el registro y deja errores/datos no sensibles en flashdata.

includes/layout/cabecera.php ? Aplica el CSS base y la hoja de estilo asignada al usuario.

includes/layout/inicio.php ? Consume el aviso de bienvenida una sola vez en cualquier p?gina.

includes/layout/pie.php ? Muestra los ?ltimos anuncios visitados en p?ginas p?blicas y privadas.

anuncio.php ? Protege el detalle y registra la visita antes de emitir HTML.

datos/usuarios.php y datos/anuncios.php ? Datos ficticios para pruebas: cuatro usuarios y cuatro anuncios indexados por ID.

# 2. Conceptos para explicar

## HTTP no conserva el estado

Cada petici?n HTTP es independiente. Para reconocer a una persona entre p?ginas, el navegador env?a una cookie PHPSESSID; PHP usa ese identificador para recuperar los datos de sesi?n guardados en el servidor.

## Cookie frente a sesi?n

? Cookie: vive en el navegador, el usuario puede verla, borrarla o modificarla. No se debe confiar en su contenido sin validarlo.

? Sesi?n: los datos viven en el servidor; el navegador solo recibe el identificador de sesi?n. Aqu? la identidad v?lida sale de $_SESSION, nunca de un par?metro de URL.

? Flashdata: valor temporal en la sesi?n que se recupera y elimina al leerlo; sirve para mensajes despu?s de una redirecci?n.

## Por qu? se renueva el ID de sesi?n

Despu?s de autenticar correctamente se llama a session_regenerate_id(true). Esto invalida el identificador anterior y reduce el riesgo de fijaci?n de sesi?n (session fixation). El auto-login tambi?n genera un ID nuevo al crear una identidad en una sesi?n an?nima.

## Token de ?Recordarme?

La cookie guarda un token aleatorio. En el servidor se conserva su hash SHA-256, caducidad y ?ltima visita. Si se filtra la base de tokens, no contiene la contrase?a del usuario; adem?s, al cerrar sesi?n se revoca el token.

# 3. Fragmentos de c?digo importantes

## Iniciar la sesi?n antes de imprimir HTML

```
session_set_cookie_params([
    'httponly' => true,
    'samesite' => 'Lax'
]);
if (session_status() === PHP_SESSION_NONE) {
    session_start();
}
// La zona horaria de la aplicaci?n es Europe/Madrid.
```

El bootstrap se incluye al principio de las p?ginas y procesadores. Las cabeceras de sesi?n/cookies deben enviarse antes de cualquier salida HTML.

## La URL no autentica; el servidor comprueba la sesi?n

```
function usuarioActual(): ?array {
    static $actual = false;
    if ($actual !== false) return $actual;

    $actual = null;
    if (!empty($_SESSION['usuario'])) {
        $actual = buscarUsuario((string)$_SESSION['usuario']);
    }
    return $actual;
}

function requiereUsuario(): array {
    $usuario = usuarioActual();
    if ($usuario === null) {
        flash_set('error', 'acceso');
        redirigir('index.php');
    }
    return $usuario;
}
```

La llamada aparece al principio de anuncio.php, mensaje.php, mensaje_enviado.php, sus procesadores y el resto de p?ginas privadas. Probar ?usuario=... no crea una sesi?n autenticada.

## Login correcto y prevenci?n de fijaci?n

```
session_regenerate_id(true);
$_SESSION['usuario'] = $email;
$usuarioDatos = buscarUsuario($email);
if ($usuarioDatos !== null && isset($usuarioDatos['estilo'])) {
    $_SESSION['estilo'] = $usuarioDatos['estilo'];
}
```

## Flashdata de un solo uso

```
function flash_get($clave) {
    if (isset($_SESSION['flash'][$clave])) {
        $valor = $_SESSION['flash'][$clave];
        unset($_SESSION['flash'][$clave]);
        return $valor;
    }
    return null;
}
```

En el registro, el procesador guarda errores y datos previamente introducidos (sin contrase?as); registro.php recupera varios valores y luego estos ya no vuelven a mostrarse.

# 4. Cookies y preferencias

## ?Recordarme? durante 90 d?as

```
$token = bin2hex(random_bytes(32));
$tokenHash = hash('sha256', $token);
// El servidor guarda tokenHash, caducidad y ?ltima visita.
setcookie('recordarme', $token, [
    'expires' => time() + (90 * 24 * 60 * 60),
    'path' => '/', 'httponly' => true,
    'secure' => !empty($_SERVER['HTTPS']) && $_SERVER['HTTPS'] !== 'off',
    'samesite' => 'Lax'
]);
```

En la petici?n siguiente, bootstrap.php compara hashes, verifica caducidad y usuario, crea la sesi?n, asigna estilo y muestra fecha/hora de ?ltima visita. La caducidad no se extiende en cada visita.

## ?ltimos anuncios visitados

```
$id = leerId(get('id'));
$anuncio = ($id !== null) ? buscarAnuncio($id) : null;
// Se conserva el orden, se elimina el ID repetido y se pone primero.
array_unshift($visitados, $id);
$visitados = array_slice(array_values($visitados), 0, 4);
setcookie('ultimos_visitados', json_encode($visitados), [
    'expires' => time() + (7 * 24 * 60 * 60),
    'path' => '/', 'httponly' => true, 'samesite' => 'Lax'
]);
```

La cookie contiene solo IDs. Cada ID se pasa por leerId() y se comprueba que buscarAnuncio() lo encuentre antes de mostrarlo. anuncio.php hace setcookie antes de incluir cabecera.php; pie.php rehidrata datos y muestra foto, t?tulo, ciudad, pa?s y precio.

## Estilo por usuario y saludo

- ? datos/usuarios.php asigna uno de los estilos noche, contraste, letra-grande o contraste-letra-grande a cada cuenta.
- ? Tras un login normal o auto-login, el estilo se copia a $_SESSION y cabecera.php emite la hoja CSS correspondiente despu?s del estilo base.
- ? saludoPorHora() usa (int)date('G'): 06?11 ?Buenos d?as?; 12?15 ?Hola?; 16?19 ?Buenas tardes?; resto ?Buenas noches?. bootstrap.php define Europe/Madrid.

# 5. Demostraci?n r?pida

## Cuentas de prueba

```
ana.lopez@ua.es       / ana1234
juana@ejemplo.com     / juana1234
alex@ejemplo.com      / alex1234
luis@ejemplo.com      / luis1234
```

Son credenciales ficticias y en texto plano porque el proyecto es una pr?ctica con usuarios de muestra; no es un sistema listo para producci?n.

## Checklist de 3 minutos

? En una ventana privada, abrir http://localhost/practica8/anuncio.php?id=1: se redirige al inicio de sesi?n aunque se a?ada ?usuario=ana.lopez%40ua.es.

? Iniciar sesi?n como Ana: se renueva PHPSESSID, aparece el men? privado y el estilo noche.

? Navegar por los detalles de los anuncios 1, 2, 3 y 4; comprobar el panel y repetir un ID para ver que cambia de posici?n sin duplicarse.

? Cerrar sesi?n: se borra la cookie ultimos_visitados y se revoca el token de recordar si exist?a.

? Repetir login con ?Recordarme?; cerrar y reabrir el navegador antes de 90 d?as: la primera p?gina entra como el usuario y muestra su ?ltima visita.

? Enviar registro inv?lido: comprobar que la URL no contiene los campos; al volver, los datos no sensibles se restauran y las contrase?as quedan vac?as.

## Qu? ocurre si la cookie se manipula

Los datos del navegador nunca se aceptan como verdad: leerId() solo acepta enteros positivos; buscarAnuncio() valida existencia; se descartan IDs duplicados y se limita la lista a cuatro. En el recordatorio, el token se compara mediante hash_equals() y se valida su fecha de caducidad.

# 6. Preguntas t?picas del profesor

### Pregunta: ?Por qu? no se puede usar ?usuario=ana como autenticaci?n?

Respuesta breve: Porque la URL la construye el cliente y cualquiera puede editarla o compartirla. La identidad debe estar respaldada por estado del servidor: $_SESSION.

### Pregunta: ?Qu? guarda PHPSESSID?

Respuesta breve: El navegador guarda el identificador opaco; los datos de sesi?n, como usuario y estilo, permanecen en el servidor.

### Pregunta: ?Por qu? no guardar la contrase?a en la cookie?

Respuesta breve: La cookie queda en el dispositivo y se puede leer o copiar. Se guarda un token aleatorio, y su hash se conserva en servidor.

### Pregunta: ?Por qu? se usa session_regenerate_id(true)?

Respuesta breve: Para invalidar el ID anterior tras autenticarse y mitigar session fixation.

### Pregunta: ?Para qu? sirve HttpOnly?

Respuesta breve: Evita que JavaScript lea esa cookie. No evita todos los ataques ni reemplaza HTTPS.

### Pregunta: ?Por qu? setcookie va antes de HTML?

Respuesta breve: Porque PHP env?a la cookie como una cabecera HTTP; las cabeceras no pueden enviarse despu?s de empezar el cuerpo de la respuesta.

### Pregunta: ?Qu? significa flashdata?

Respuesta breve: Dato temporal de sesi?n para una redirecci?n; el destino lo consume una sola vez y despu?s se elimina.

### Pregunta: ?Qu? se borra al salir?

Respuesta breve: Se vac?a el estado autenticado, se invalida el token persistente del usuario recordado y se elimina la cookie de anuncios vistos.

### Pregunta: ?Por qu? leer y validar IDs de la cookie?

Respuesta breve: Porque el cliente controla el contenido de su cookie; podr?a inventar IDs, enviar valores malformados o duplicados.

# 7. Estado de revisi?n y l?mites conocidos

### Requisitos del enunciado revisados

? Autenticaci?n solo desde sesi?n; protecci?n de p?ginas privadas y regeneraci?n del identificador.

? Recordatorio persistente por 90 d?as sin guardar contrase?as; mensaje de ?ltima visita y revocaci?n al salir.

? Flashdata en login y registro; estilos asignados por usuario; saludo por franja horaria.

? Panel com?n de cuatro anuncios vistos, cookie de una semana y borrado en logout.

? Datos del panel recuperados desde anuncios por ID real, con validaci?n de IDs manipulables.

### Cosas que conviene aclarar

? La b?squeda de resultado_busqueda.php sigue siendo demostrativa: muestra dos tarjetas fijas aunque los criterios introducidos pueden pedir otra cosa. No es requisito central de cookies/sesiones, pero conviene completarla si tambi?n se eval?a el buscador.

? La cookie de ?ltimos anuncios es por navegador. Si dos cuentas usan el mismo navegador, comparten ese panel en el dise?o actual; el enunciado menciona una lista por usuario.

? Los usuarios de ejemplo guardan contrase?as en texto plano y recordar.json es un archivo local. En producci?n se usar?an password_hash()/password_verify(), almacenamiento persistente apropiado, HTTPS obligatorio y controles de despliegue.

? El flujo de mensaje enviado todav?a pone tipo y texto en la URL de confirmaci?n. No es un requisito de flashdata especificado para esta pr?ctica, pero ser?a mejor pasar ese contenido con flashdata para evitar historial y logs con el texto del mensaje.

? El .gitignore evita a?adir recordar.json en commits futuros, pero si el archivo ya estuviera versionado debe dejar de seguirse expl?citamente. En este directorio no se pudo comprobar el estado de Git.

Estos puntos no invalidan la explicaci?n de los requisitos principales; presentarlos como l?mites conocidos demuestra que se distingue una pr?ctica did?ctica de un sistema de producci?n.

# 8. Fuentes r?pidas dentro del proyecto

Para ense?ar el c?digo en el editor, conviene abrir estos archivos:

? includes/bootstrap.php ? sesi?n, flashdata y auto-login.

? includes/lib/funciones.php ? identidad, guard de acceso y saludo.

? includes/procesadores/control_acceso.php ? login, token y renovaci?n de sesi?n.

? includes/procesadores/cerrar_sesion.php ? logout.

? anuncio.php + includes/layout/pie.php ? cookie de visitas y panel com?n.

? includes/procesadores/respuesta_registro.php + registro.php ? flashdata del registro.

? includes/layout/cabecera.php + datos/usuarios.php ? estilos por usuario.